

北京林业大学

数据库原理与应用

数据库安全内容概述



企业的
业务过程信息

国家机构的
业务管理信息

国防情报等
具有密级的信息



存储和使用



存储和使用



数据库



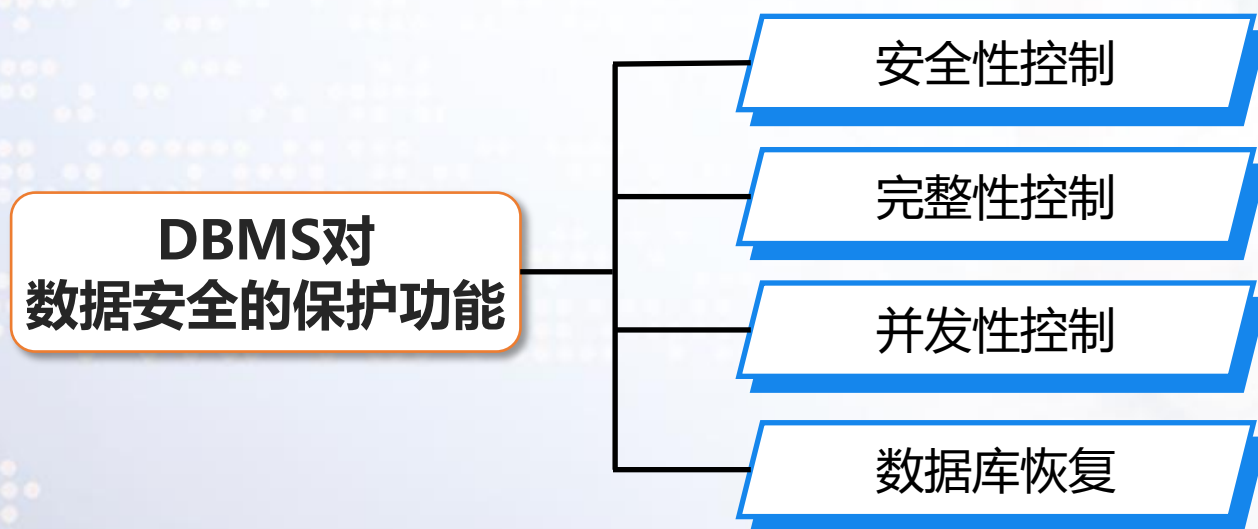
管理

DBMS



数据库安全内容概述

为了适应和满足数据共享的环境和要求，DBMS要保证整个系统的正常运转，防止数据泄露，恶意修改，不一致产生，产生问题后的及时恢复，需要一整套而有效的保护措施。





数据库安全内容概述

数据库安全内容针对的问题

安全性控制



防止数据泄露，恶意修改

完整性控制



防止数据的不一致性

并发性控制



数据库恢复



产生问题后的及时恢复

数据库安全性含义、 控制方法及SQL Server安全性机制

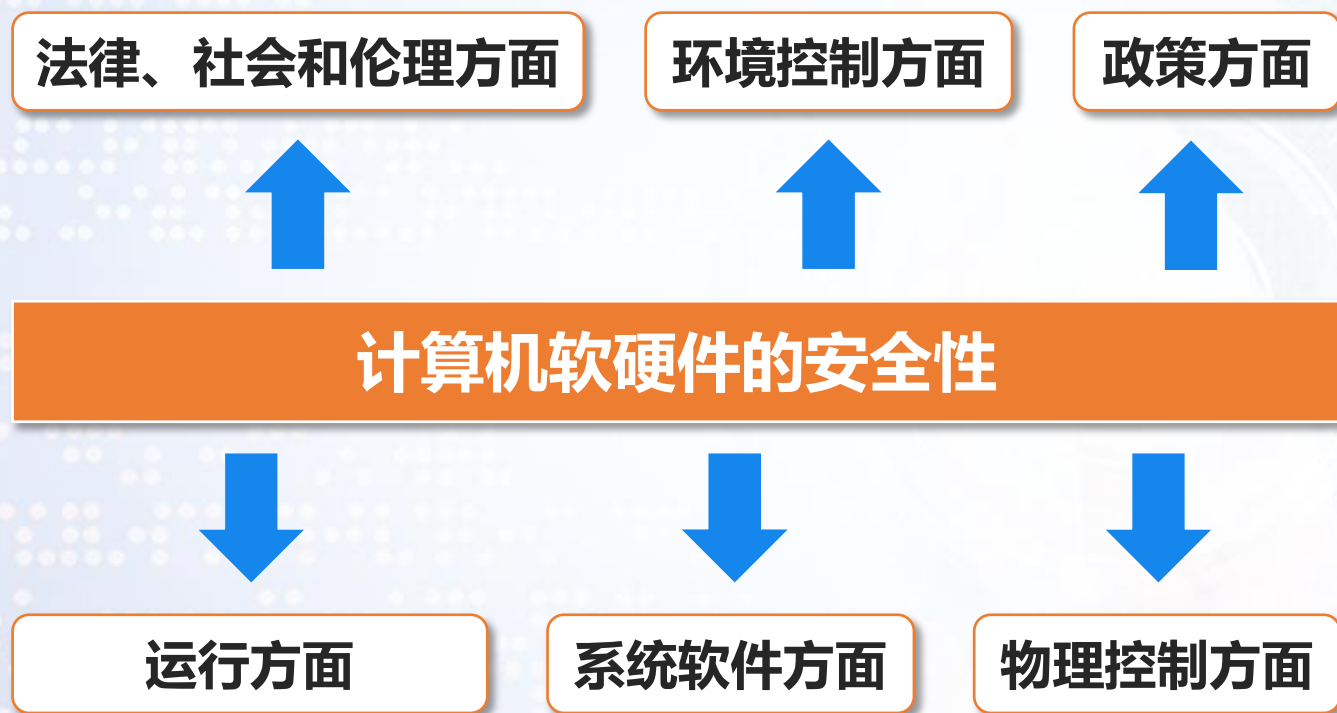
本章目录 CONTENTS

- | 数据库安全性含义
- | 安全性控制的一般方法
- | SQL Server数据库安全性机制
- | 总结

数据库安全性 含义



数据库安全性含义



数据库的安全性是指保护数据库以防止非法使用所造成的数据泄露、更改或破坏。

安全性控制的一般方法



安全性控制的主要问题

安全性控制是指要尽可能地杜绝所有可能的数据库非法访问。

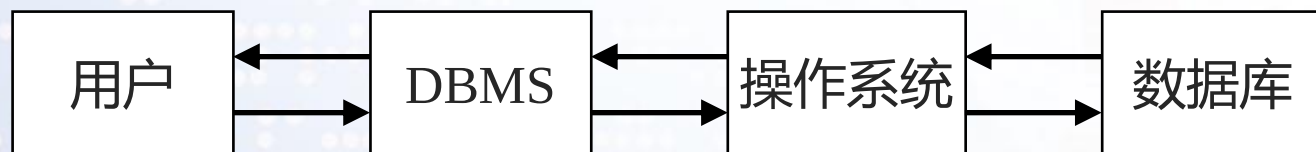
面临的问题：

- ◆ 编写合法的程序绕过DBMS的安全管理机制，直接在操作系统上，读取、修改相关数据。
- ◆ 用户登录数据库管理系统后，使用了不在其权限范围中的数据。
- ◆



安全性控制模型

- ◆ 安全性不仅是数据库层面的问题，在计算机系统中都存在这个问题。
- ◆ 在计算机系统中，安全措施是通过层层设置的，安全模型的层次如下：



安全控制模型的层次



数据库安全性控制的手段

用户标识和鉴定

用户存取权限控制

定义视图

数据加密

数据审计

数据库安全性 控制手段



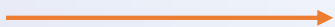
用户标识和鉴定

手段概述

- ◆ 由系统提供一定的方式让用户**标识自己的名字或身份**，系统内部记录着所有**合法用户的标识**。
- ◆ 每次用户要求进入系统时，由系统进行核实，**通过鉴定后才提供机器的使用权**。



用户提供标识



系统

用户提供标识

比较

存储合法标识





用户标识和鉴定

标识的表示方法

- ◆ 用一个用户名或用户标识符来标明用户的身份，系统以此来鉴别用户的合法性。



友情提醒：初次登陆成功后，将自动进行邮件搬家。旧邮箱通讯录需要手工导出后再导入新邮件系统。客户端收发信需修改配置，收信服务器：pop.bjfu.edu.cn, 发信服务器：smtp.bjfu.edu.cn。

登陆北林邮箱

☐ 保持我的登录状态 [忘记密码](#)

腾讯即时通讯RTX北京林业大学版下载



用户标识和鉴定

标识的表示方法

- ◆ 用户标识符是用户公开的标识，它不足以成为鉴别用户身份的凭证。
- ◆ 通过用户名和口令来鉴定用户的方法简单易行，但用户名和口令的产生和使用比较简单，也容易被窃取，因此还可采用更复杂的方法。



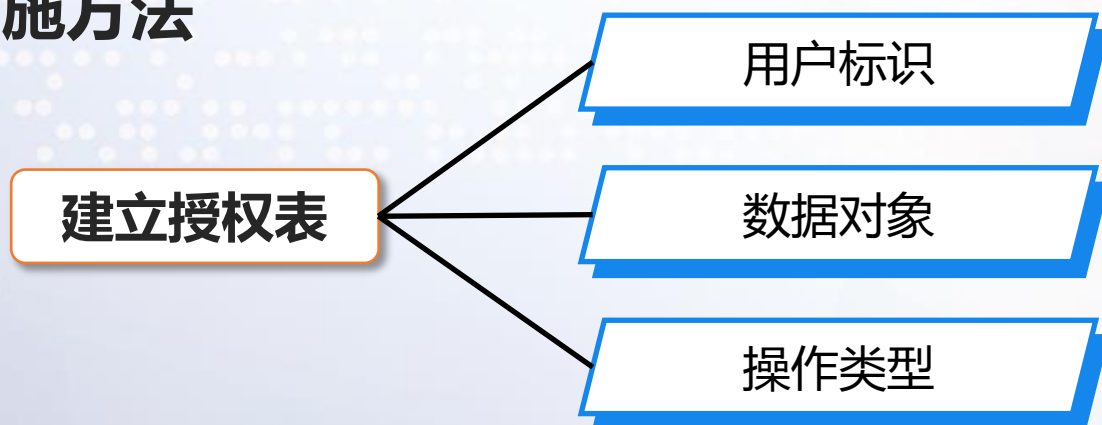


用户存取权限控制

手段概述

- ◆ 用户存取权限指的是不同的用户对于不同的数据对象允许执行的操作权限。
- ◆ 在数据库系统中，定义用户存取权限称为授权。
- ◆ 这些授权定义经过编译后以一张授权表的形式存放在数据字典中。

实施方法





用户存取权限控制

存取权限的例子

数据对象		操作类型
模式	模式	建立、修改、检索
	外模式	建立、修改、检索
	内模式	建立、修改、检索
数据	表	查找、插入、修改、删除
	属性列	查找、插入、修改、删除

- ◆ 对于授权的使用，一个衡量授权机制的重要指标就是授权粒度，即可以定义的数据对象的范围，在关系数据库中，授权粒度包括关系、记录或属性。
- ◆ 授权粒度越细，授权子系统就越灵活，能够提供的安全性就越完善。



定义视图

手段概述

- ◆ 为不同的用户定义不同的视图，可以限制各个用户的访问范围。
- ◆ 视图是逻辑存在的，其修改操作会受到限制。

实施方法





数据加密

手段概述

加密的基本思想是根据一定的算法将原始数据加密成为不可直接识别的格式，数据以密文的形式存储和传输。

实施方法

- ◆ 替换方法，该方法使用密钥将明文中的每一个字符转换为密文中的字符。
- ◆ 转换方法，该方法将明文中的字符按不同的顺序重新排列。

通常将这两种方法结合起来使用，就可以达到相当高的安全程度。



数据审计

手段概述

- ◆ 审计功能是一种监视措施，它跟踪记录有关数据的访问活动。
- ◆ 审计追踪把用户对数据库的所有操作自动记录下来，存放在一个特殊文件中，即审计日志中。

记录的内容一般包括：

操作类型（如修改、查询等），操作终端标识与操作者标识，操作日期和时间，操作所涉及到的相关数据（如基本表、视图、记录、属性等），数据的前象和后象等。

SQL Server 数据安全性机制



三层安全结构

结合安全性模式以及安全性控制手段，SQL Server使用了2层结构的数据库安全机制，表现为：



总结



总结

安全性控制的一般方法

用户标识与鉴定

用户存取权限控制

定义视图

数据加密

数据审计

SQL Server 数据安全机制

服务器级别的安全性

具体数据库及其对象的安全性

服务器级别安全性管理

主要内容

CONTENTS

- | SQL Server登录账号的相关操作
- | SQL Server身份验证模式
- | SQL Server服务器角色
- | 总结

SQL Server登录 账号的相关操作

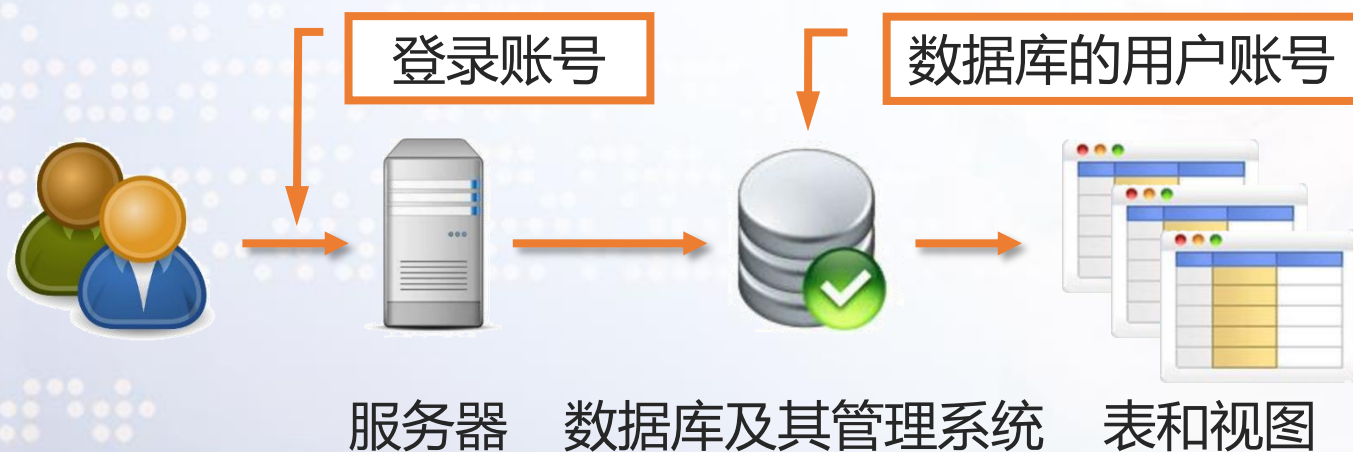


登录账号和用户账号

在SQL Server中，账号有两种：

登录账号 (Login Name)

数据库的用户账号 (User Name)





创建登录账号的过程



创建登录账号的用户名和密码等登录标识信息。



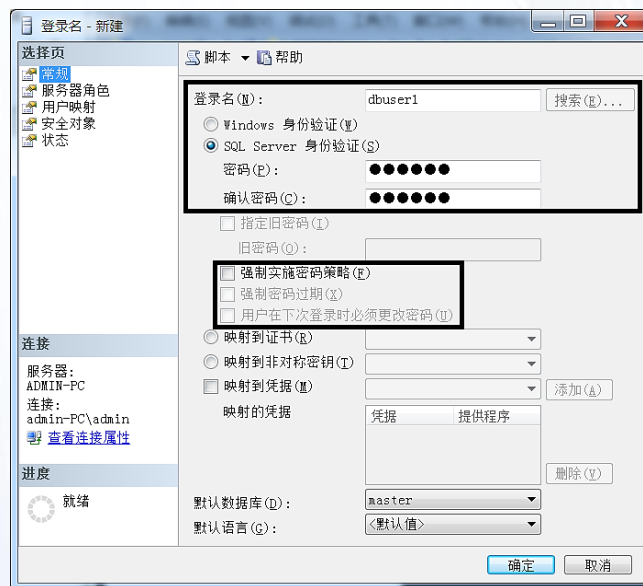
创建登录账号的服务器角色



创建登录账号的登录名、验证模式和密码

步骤如下:

1. '对象资源管理器' ;
2. 展开 '安全性' 节点;
3. 右键单击 '登录名' ;
4. 选择 '新建登录名' ;
5. 输入登录名;
6. 选择身份验证模式;
7. 输入密码并确认;
8. 选择密码策略。

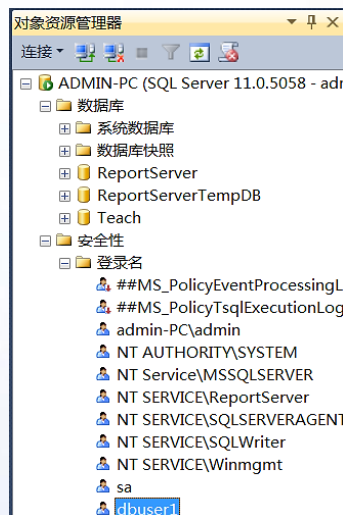
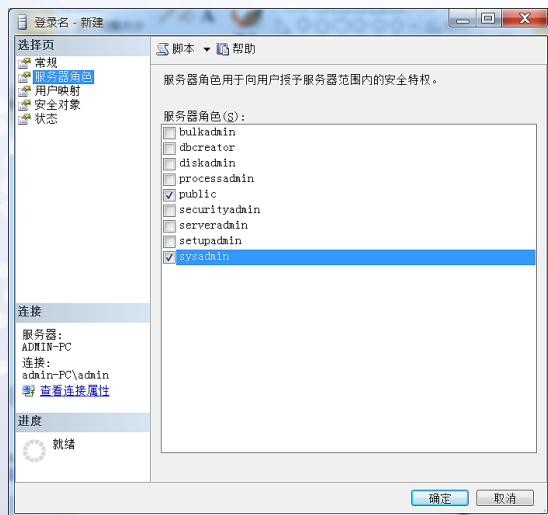




指定登录账号的服务器角色

步骤如下：

1. 选择 '服务器角色' ；
2. 确定服务器角色并点击 '确认' 。





修改和删除登录账号

○ 修改登录账号

在‘对象资源管理器’中展开‘安全性’节点下面的‘登录名’节点，右键选择要修改的登录名，选择弹出菜单中的‘属性’菜单就可以对登录账号进行修改。

○ 删除登录账号

在‘对象资源管理器’中展开‘安全性’节点下面的‘登录名’节点，右键选择要删除的登录名，选择弹出菜单中的‘删除’菜单即可删除指定的登录账号。

SQL Server 身份验证模式

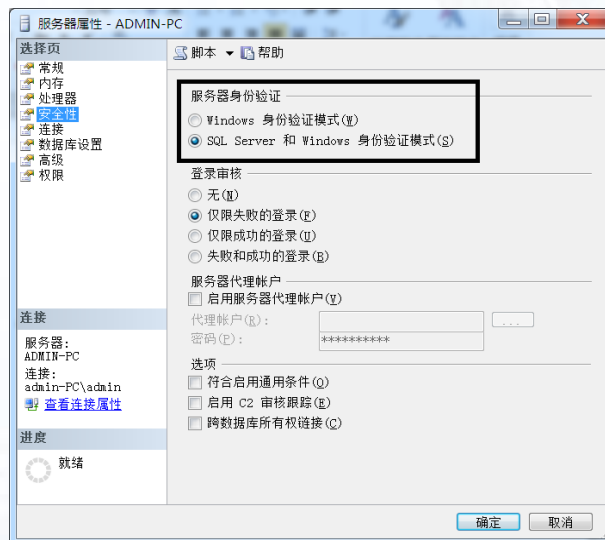


SQL Server身份验证方法的设置



步骤如下:

1. '对象资源管理器' 中
2. 右键 '服务器'
3. 弹出菜单中选择 '属性'
4. '服务器属性' 窗口中
5. '选择左侧的 '安全性''
6. 选择身份验证模式
7. 重启SQL Server





两种主要的验证模式

Windows身份验证

使用Windows操作系统进行用户的登录身份验证

将验证用户的工作让windows进行。

只支持windows环境的验证。

混合验证方式

SQL Server自行进行用户的登录身份验证

支持非windows用户登录。

一般用于各类Web程序应用使用数据库的情况。

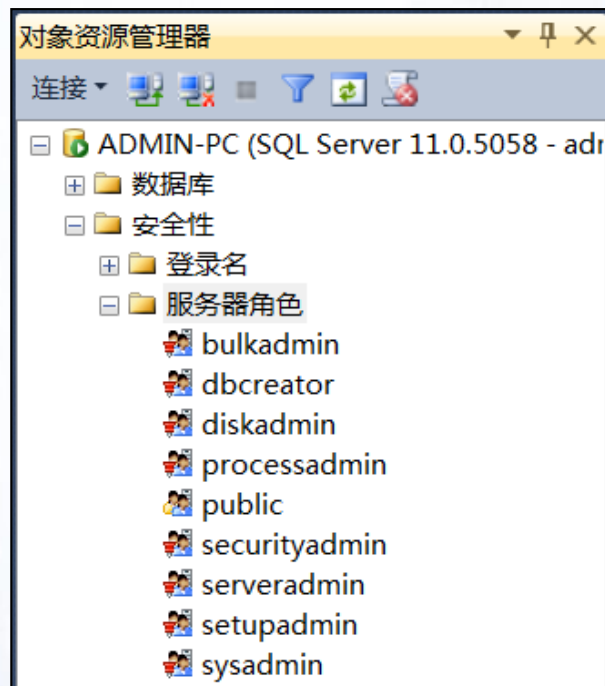
SQL Server 服务器角色



SQL Server服务器角色的查看

主要步骤:

1. 角色是权限的集合，将不同权限根据业务关系，组成角色。
2. SQL Server默认提供的角色如图所示：





默认安装的角色权限概述

服务器角色	描 述
bulkadmin	允许非sysadmin用户运行BULK INSERT语句
dbcreator	创建、更改、删除和还原任何数据库
diskadmin	管理磁盘文件
processadmin	终止SQL Server实例中运行的进程
public	每个 SQL Server 登录账号都属于 public 服务器角色
securityadmin	管理登录名及其属性
serveradmin	更改服务器范围的配置选项和关闭服务器
setupadmin	添加和删除链接的服务器，并且也可以执行某些系统存储过程
sysadmin	在服务器中执行任何活动



数据库管理员不能创建服务器角色，只能够将其他角色或者用户添加到服务器角色中。

总结



知识点总结



SQL Server具体数据库级安全管理

主要内容 CONTENTS

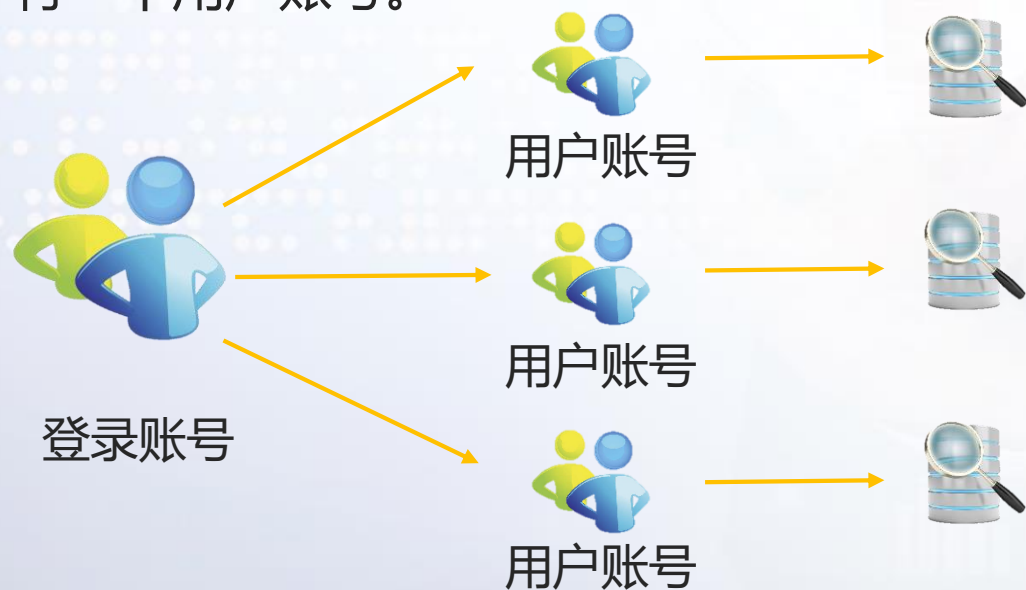
- | 数据库用户账号的相关操作
- | 数据库角色
- | 用户权限管理
- | 总结

数据库用户账号的相关操作



数据库用户账号

- ◆ 用户账号要在特定的数据库内创建，并关联一个登录账号（当一个数据库的用户创建时，必须关联一个登录账号）。
- ◆ 每个登录账号在一个数据库中只能有一个用户账号，但每个登录账号可以在不同的数据库中各有一个用户账号。





创建数据库用户账号

创建账户的方式

使用 '对象资源管理器'

使用SQL语句



创建数据库用户账号



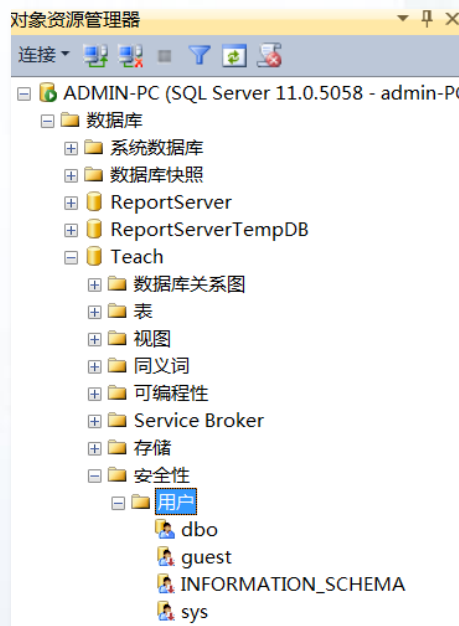
使用 ‘对象资源管理器’

1. 打开 ‘对象资源管理器’

2. 开展要创建用户的数据库

3. 找到其下的 ‘安全性’ 节点

4. 右键点击出现的用户文件夹





创建数据库用户账号



使用 ‘对象资源管理器’

1.右键 ‘用户’ 文件夹

2.点击 ‘新建用户’

3.添加 ‘常规选项卡’ 中信息

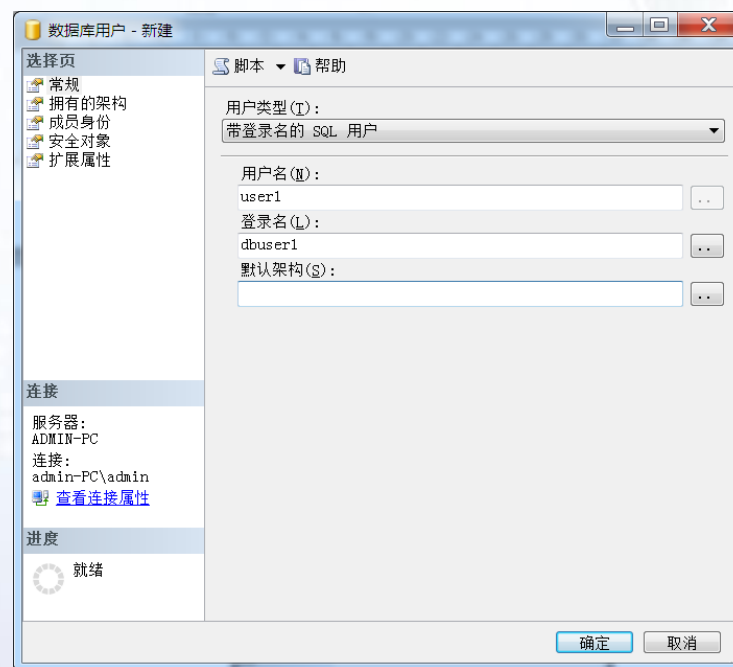


创建数据库用户账号



使用 ‘对象资源管理器’

- ◆ 登录名：
对应的登录账号
- ◆ 默认架构：
该用户所属架构
- ◆ 拥有的架构查看
和设置该用户拥有的架构。



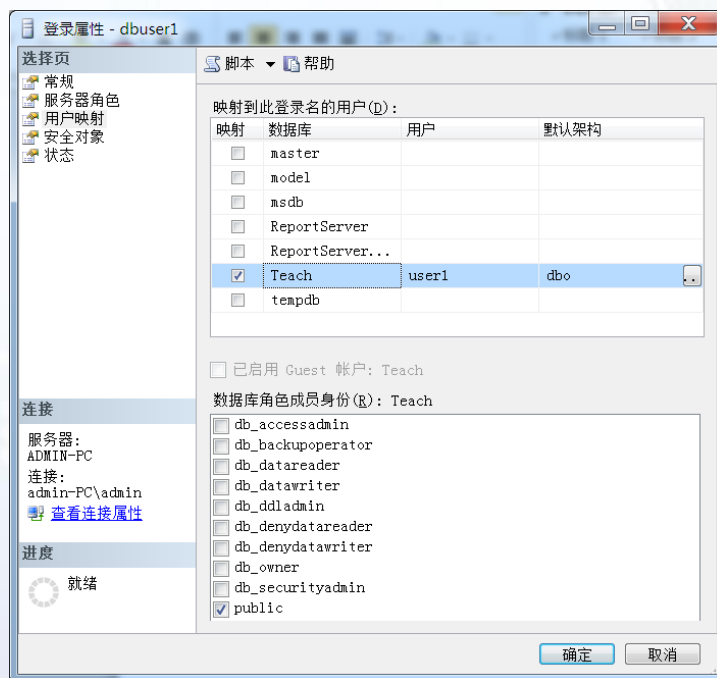


创建数据库用户账号



使用 ‘对象资源管理器’

◆ 使用用户映射查看数据库用户账号和登录账号的绑定关系。





创建数据库用户账号



使用语句创建

- ◆ user_name:数据库用户名。
- ◆ login_name:登录用户名。

```
Create User user_name  
[ {For | From }  
{  
    Login login_name  
    | Certificate cert_name  
    | Asymmetric Key asym_key_name  
}  
| Without Login  
]
```



修改和删除数据库用户账号

修改步骤如下：

- ✓ 和创建用户的方法类似，找到数据库下的‘安全’文件夹节点。
- ✓ 在文件夹下找到所要修改的用户。
- ✓ 右键该用户，选择属性，则可以按照对话框修改用户信息。



修改和删除数据库用户账号

删除步骤如下：

- ✓ 和创建用户的方法类似，找到数据库下的‘安全’文件夹节点。
- ✓ 在文件夹下找到所要删除的用户。
- ✓ 右键该用户，选择删除对象，则可以删除用户信息。

数据库角色



数据库角色概述

角色名称	权限
public	最基本的数据库角色
db_accessadmin	可以添加或删除用户标识
db_backupoperator	可以发出DBCC、CHECKPOINT和BACKUP语句
db_datareader	可以选择（取）数据库内任何用户表中的所有数据
db_datawriter	可以更改数据库内任何用户表中的所有数据
db_ddladmin	可以发出所有DDL语句，但不能发出GRANT（授权）、REVOKE或DENY语句
db_denydatareader	不能选择（取）数据库内任何用户表中的任何数据
db_denydatawriter	不能更改数据库内任何用户表中的任何数据
db_owner	在数据库中有全部权限
db_securityadmin	可以管理全部权限、对象所有权、角色和角色成员资格

用户权限管理



用户权限管理分类

权限管理分类



系统权限

- ◆ 用户对数据库的权限操作
创建数据库、数据表、存储过程等。



对象权限

- ◆ 用户对特定数据库对象操作
对表和视图的操作

总结



知识点总结



数据库安全

创建用户的方式

修改用户的方式

删除用户的方式



用户权限管理